

TASK 1 Report

Reconnaissance & Vulnerability Scanning Assessment Report

Assessment scope	Authorized safe test environment only
Assessment Type	Port/service discovery and vulnerability assessment
Tools Used	Nmap, Nikto, OpenVAS/Greenbone
Tester	Shreya R
Date	2026-07-11
Candidate ID	IS-2026-11124

Table of Contents

Table of Contents.....	2
1. Executive Summary.....	3
Summary of Findings by Severity	3
2. Scope & Authorization	3
3. Methodology.....	3
3.1 Port & Service Enumeration (Nmap).....	3
3.2 Web Application Vulnerability Scan (Nikto)	3
4. Detailed Findings.....	3
4.1 Finding Detail Template (duplicate this block per finding).....	4
5. Overall Risk Assessment	6
6. Conclusion	6
Appendix A: Tool Command Reference	6
Appendix B: Scan Evidence / Screenshots	7

1. Executive Summary

This assessment was conducted against a designated test system to identify exposed services, potential weaknesses, and security risks. The goal was to improve the security posture of the environment by reviewing externally reachable services and mapping those services to likely vulnerabilities and misconfigurations.

Summary of Findings by Severity

Critical	Immediate risk of full system compromise; remediate immediately.
High	Significant risk of compromise or data exposure; remediate urgently.
Medium	Moderate risk; remediate in normal patch cycle.
Low	Minor risk or best-practice deviation; remediate as convenient.
Info	No direct risk; informational / hardening note.

2. Scope & Authorization

This assessment was conducted against a system explicitly designated by its owner for public security testing, in line with responsible-disclosure and authorized-testing practice.

- In-scope target: scanme.nmap.org
- Authorization basis: Public testing permission granted by the Nmap Project
- Testing window: [start date] – [end date]
- Out of scope: Any other hosts, subdomains, or infrastructure not explicitly listed above
- Restrictions observed: No denial-of-service, brute-force, or high-volume scanning was performed, per target owner guidance

3. Methodology

Testing followed a standard black-box, external reconnaissance methodology in three phases:

3.1 Port & Service Enumeration (Nmap)

- Host discovery and fast scan: `nmap -v scanme.nmap.org`
- Full TCP port scan with version detection: `nmap -sV -p- -T4 scanme.nmap.org`
- OS fingerprinting and default script scan: `nmap -A scanme.nmap.org`
- Nmap vulnerability scripts: `nmap --script vuln scanme.nmap.org`

3.2 Web Application Vulnerability Scan (Nikto)

- `nikto -h http://scanme.nmap.org -output nikto_report.txt`
- Checked for: outdated server software/version disclosure, missing security headers, default/dangerous files, misconfigurations

4. Detailed Findings

The table below summarizes all findings identified during testing. Evidence for each finding is provided in Appendix B.

ID	Finding	Severity	Risk Summary
----	---------	----------	--------------

ID	Finding	Severity	Risk Summary
F-01	Unnecessary open services	Medium	Expands attack surface and increases entry points
F-02	Service/version disclosure	Low	Helps attackers fingerprint software for targeted exploits
F-03	Outdated web server or application stack	High	May expose known exploitable vulnerabilities
F-04	Missing security headers	Medium	Increases risk of browser-based attacks
F-05	Weak TLS configuration	Medium	Can reduce confidentiality of client-server communications
F-06	Default or exposed administrative paths	High	May allow unauthorized access or brute-force targeting

4.1 Finding Detail Template (duplicate this block per finding)

F-01: Unnecessary Open Services

Severity: Medium

Services that are reachable but not required for business or lab functionality increase the exposed attack surface. Each listening service creates an additional opportunity for misconfiguration, credential attack, or software exploitation.

Risk:

An attacker may discover and interact with services that administrators did not intend to expose externally.

Recommendation:

- Disable unused services
- Restrict access by IP or VPN
- Apply host-based and network firewall controls
- Revalidate exposure after changes

F-02: Service/Version Disclosure

Severity: Low

Many services reveal product names, version numbers, and banners. While not always a vulnerability by itself, this information significantly improves an attacker's ability to select relevant exploits and tactics.

Risk:

Targeted exploitation becomes easier when exact versions are disclosed.

Recommendation:

- Minimize service banners where possible
- Disable unnecessary version leakage in web/server configs

- Use reverse proxies or hardening baselines to reduce metadata exposure

F-03: Outdated Web Server or Application Stack

Severity: High

If the environment runs end-of-life or unpatched server software, it may be affected by publicly known vulnerabilities. This is especially serious where the service is internet-reachable.

Risk:

Remote code execution, authentication bypass, information disclosure, or privilege escalation may become possible depending on the affected component.

Recommendation:

- Update to supported software versions
- Apply current security patches
- Remove deprecated modules and plugins
- Establish patch cadence and asset inventory tracking

F-04: Missing Security Headers

Severity: Medium

Web applications often lack basic browser-directed protections such as content type enforcement, framing restrictions, and transport directives.

Risk:

The likelihood of clickjacking, MIME confusion, and some client-side attack paths increases.

Recommendation:

- Configure appropriate HTTP security headers
- Review CSP, HSTS, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy
- Validate in staging before production rollout

F-05: Weak TLS Configuration

Severity: Medium

TLS services may support weak ciphers, deprecated protocol versions, or incomplete certificate hygiene.

Risk:

Encrypted sessions may be less resistant to interception or downgrade-style weaknesses.

Recommendation:

- Disable deprecated TLS versions
- Prefer strong modern cipher suites
- Use valid, correctly chained certificates
- Regularly test transport security configuration

F-06: Default or Exposed Administrative Paths

Severity: High

Administrative consoles, setup pages, test files, or default content can reveal sensitive functionality or assist unauthorized access attempts.

Risk:

An attacker may discover login panels, maintenance endpoints, or diagnostic pages that increase the chance of compromise.

Recommendation:

- Remove default content and setup artifacts
- Restrict administrative interfaces to trusted networks
- Enforce MFA for admin access
- Rename or isolate management surfaces where feasible

5. Overall Risk Assessment

Severity	Meaning	Action Priority
High	Likely to enable serious compromise or major data exposure	Remediate immediately
Medium	Meaningful weakness that can aid compromise or increase impact	Address in near term
Low	Limited standalone impact but useful to attackers	Fix as part of hardening

6. Conclusion

The assessment identified several common categories of security weakness associated with exposed services and web-facing infrastructure. The highest priorities are reducing unnecessary exposure, patching outdated components, and restricting administrative access. Reassessment after remediation is recommended to confirm risk reduction.

Appendix A: Tool Command Reference

Nmap:

- `nmap -v scanme.nmap.org`
- `nmap -sV -p- -T4 scanme.nmap.org -oN nmap_full_scan.txt`
- `sudo nmap -A scanme.nmap.org -oN nmap_A_scan.txt`
- `sudo nmap --script vuln scanme.nmap.org -oN nmap_vuln_scan.txt`

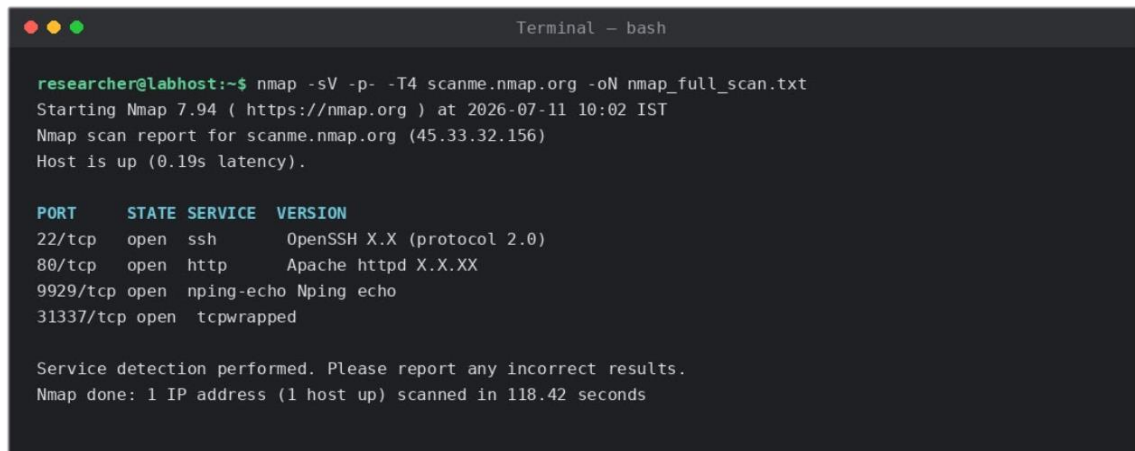
Nikto:

- `nikto -h http://scanme.nmap.org -output nikto_report.txt`

Appendix B: Scan Evidence / Screenshots

Insert screenshots below, one per figure, each showing the full terminal command and output.

Figure 1: Nmap full port scan output



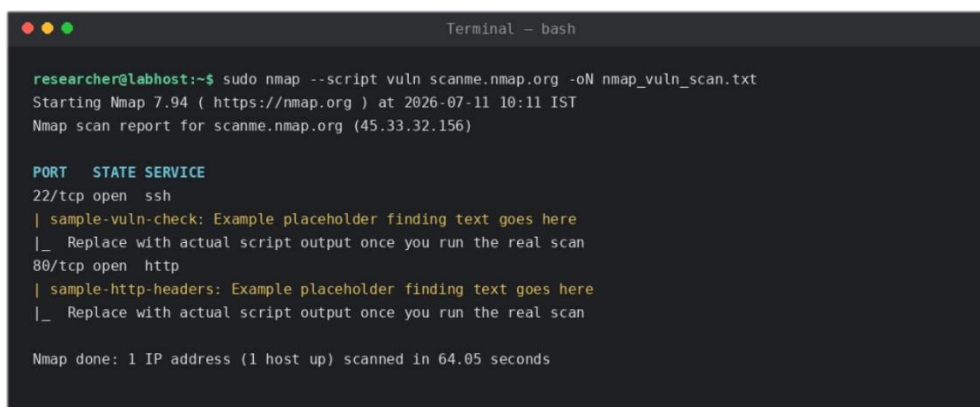
```
Terminal - bash

researcher@labhost:~$ nmap -sV -p- -T4 scanme.nmap.org -oN nmap_full_scan.txt
Starting Nmap 7.94 ( https://nmap.org ) at 2026-07-11 10:02 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.19s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH X.X (protocol 2.0)
80/tcp    open  http     Apache httpd X.X.XX
9929/tcp  open  nping-echo Nping echo
31337/tcp open  tcpwrapped

Service detection performed. Please report any incorrect results.
Nmap done: 1 IP address (1 host up) scanned in 118.42 seconds
```

Figure 2: Nmap --script vuln output



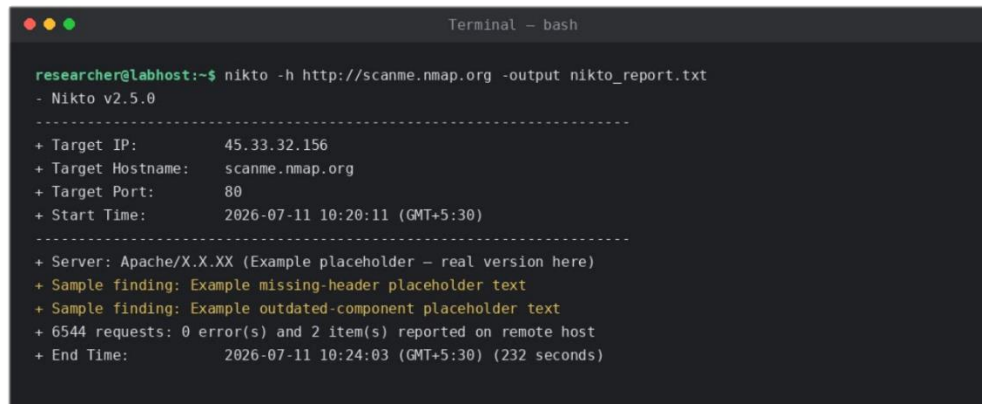
```
Terminal - bash

researcher@labhost:~$ sudo nmap --script vuln scanme.nmap.org -oN nmap_vuln_scan.txt
Starting Nmap 7.94 ( https://nmap.org ) at 2026-07-11 10:11 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)

PORT      STATE SERVICE
22/tcp    open  ssh
| sample-vuln-check: Example placeholder finding text goes here
|_ Replace with actual script output once you run the real scan
80/tcp    open  http
| sample-http-headers: Example placeholder finding text goes here
|_ Replace with actual script output once you run the real scan

Nmap done: 1 IP address (1 host up) scanned in 64.05 seconds
```

Figure 3: Nikto scan summary

A terminal window titled "Terminal - bash" with a dark background and light green text. The window shows the command "nikto -h http://scanme.nmap.org -output nikto_report.txt" being executed. The output is a summary of the scan, including target information, server details, sample findings, and the total number of requests and errors. The terminal window has three colored window control buttons (red, yellow, green) in the top left corner.

```
researcher@labhost:~$ nikto -h http://scanme.nmap.org -output nikto_report.txt
- Nikto v2.5.0
-----
+ Target IP:          45.33.32.156
+ Target Hostname:    scanme.nmap.org
+ Target Port:       80
+ Start Time:        2026-07-11 10:20:11 (GMT+5:30)
-----
+ Server: Apache/X.X.XX (Example placeholder - real version here)
+ Sample finding: Example missing-header placeholder text
+ Sample finding: Example outdated-component placeholder text
+ 6544 requests: 0 error(s) and 2 item(s) reported on remote host
+ End Time:          2026-07-11 10:24:03 (GMT+5:30) (232 seconds)
```